

RFP 기반 인프라구축을 위한 가이드라인

[보안 네트워크 구축]

본 문서는 실무형 엔지니어 양성을 위한 제안 요청서(RFP)의 가이드라인입니다.

1. 기본 정보 및 개요

항목	내용
과정명	정보보안 기반 클라우드, 서버 DevOps 인프라 및 네트워크 구성을 통한 실무형 엔지니어 양성
수신 대상	KDT 프로젝트 과정 참여 훈련생
참여기업 멘토	(에스넷시스템) 길성흠 멘토

본 프로젝트는 본사, 지사, DMZ, 내부망으로 분리된 엔터프라이즈 네트워크를 설계하며, 실제 기업 환경 수준의 보안 네트워크 구축을 목표로 한다. 또한 레드팀의 모의해킹 공격과 블루팀의 보안 방어 실습을 통해 인프라 보안 능력을 검증한다.

2. 요구사항

[요구사항 01] 라우터/스위치/방화벽 활용한 보안 인프라 구축

라우터, 스위치, 방화벽 장비를 활용하여 안전한 네트워크 망을 설계하고, 보안 등급에 따라 서버 영역을 적절히 배치한다.

- 라우터: 정적 라우팅(Static Routing) 및 동적 라우팅(RIPv2) 설정을 통한 WAN 영역 연동
- 스위치: VLAN, Trunking, DTP 차단, VTP 설정을 활용한 안전한 LAN 영역 완성
- 방화벽: pfSense를 활용하여 내부망(LAN), 외부망(WAN), DMZ 영역의 경계 보안 설정

[요구사항 02] 레드팀의 모의해킹 공격과 블루팀의 보안 방어

1단계에서 구축한 망의 취약점을 파악한 후 모의해킹을 진행하고 이에 관한 보안설정을 적용한다.

- **레드팀 공격:** 취약점 분석, 각종 공격, 자동화 코드를 활용한 정보 수집
- **블루팀 방어:** 라우터의 ACL과 인증설정, 스위치의 내부망 분리, 트래픽 모니터링, 방화벽을 이용한 영역분리, Snort를 이용한 탐지

3. 진행 과정 및 세부 기술 내용

[세부 진행 내용]

가. 단계별 진행 프로세스

- 1단계: 인프라 구축 및 가용성 확보
- 2단계: 취약점 분석 및 패킷 모니터링 환경 설정
- 3단계: 취약점 기반 모의해킹 공격 수행 (레드팀)
- 4단계: 인프라 보안 강화 및 탐지 규칙 적용 (블루팀)

나. 세부 기술 내용

구분	세부 기술
네트워크 구축 및 라우팅	- 내외부망 경계 라우팅 구현 및 라우터 기본 보안 설정 - 정적 라우팅 및 RIPv2 기반의 경계망 연동
네트워크 구축 및 스위칭	- 3계층 서브넷 설계안에 따른 VLAN 매핑 및 스위치 간 트렁크(Trunk) 설정 - 보안 취약점 제거를 위한 DTP(Dynamic Trunking Protocol) 비활성화 - VTP 도메인 및 패스워드 설정을 통한 VLAN 정보 동기화
보안 서버 영역 구축	- 인프라 서비스 활성화: Telnet, SSH, HTTP, DHCP 서버 설정 - 호스트기반 방화벽 설정: ufw, iptables 를 활용한 보안 설정
레드팀 모의해킹 수행	1) 취약점 분석 및 포트 스캐닝: 네트워크 서비스 식별 - netdiscover, ping, nmap 활용 대상 서버 서비스 및 포트 확인 - 스캔 결과 분석 및 취약점 기록

구분	세부 기술
	2) 무차별 대입(Brute Force) 공격 - Telnet, SSH, HTTP 로그인 페이지를 hydra, medusa를 이용한 ID/PWD 무차별 대입 - 무차별 대입 공격으로 성공한 ID/PW → 실제 서비스 접근 시도, 결과 기록 3) RIP 프로토콜 Spoofing 공격 - Scapy를 이용해 위조된 RIP Update 패킷 생성 - 네트워크에 존재하지 않는 경로(예: 8.8.8.0/24)를 대상 라우터의 라우팅 테이블에 삽입 - 대상 라우터의 RIP 멀티캐스트 주소(224.0.0.9)로 혹은 유니캐스트(공격대상 라우터IP) 위조 패킷 전송 4) DHCP pool starvation, DNS spoofing 공격 - 라우터 혹은 DHCP 서버를 대상으로 DHCP pool 고갈 공격 - DNS Spoofing을 통한 악성 웹 페이지 리다이렉션 수행 - msfconsole, scapy 등 활용 5) 자동화 코드를 활용한 정보 수집 및 공격 - 파이썬 라이브러리를 활용한 각종 설정 정보 수집(라우팅 테이블, VLAN DB) 및 설정 변경 구현
블루팀 보안 방어 설계	1) 트래픽 모니터링 - SPAN 설정(port mirroring)으로 특정 포트 트래픽 미러링 - Wireshark, tcpdump 를 활용한 패킷 분석 및 보고서 작성 2) 라우터 ACL 설정 - 공격 트래픽 차단, 관리자 트래픽 허용 규칙 구성 3) 라우팅 정보 무결성 검증 - 라우터에서 RIP 업데이트 시 인증키(MD5 등)를 사용해 허가된 라우터간에만 라우팅 정보 교환 - RIP spoofing 공격 차단 4) 스위치에서 DHCP snooping 설정 - DHCP pool starvation 공격 차단 5) 방화벽(pfSense)에 LAN, WAN, DMZ 구축을 통한 영역 분리 - DMZ영역에는 외부 접속이 가능한 Web Server 구축 - 방화벽 정책(Rule) 기반의 트래픽 허용 및 차단 - NAT/Port Forwarding 구성 - Snort를 이용한 특정 패킷 탐지

다. 세부 기술 구현 필수 조건

- RFC 1918 사설 IP 주소 대역 중 10.0.0.0/8 대역을 효율적으로 서브네팅하여 할당한다.
- 시스코 가상 네트워크 장비를 메인으로 사용하며, 방화벽은 오픈소스 pfSense를 사용한다.
- 내부망의 IP 주소 은닉과 외부 통신을 위해 라우터 또는 방화벽에서 NAT(Network Address Translation) 설정을 적용한다.

4. GNS3 등을 활용한 가상환경 구현

- 동일한 VMware Workstation 하이퍼바이저 내에서 동작하는 GNS3 VM과 가상 머신들(Kali Linux, Ubuntu Server/Desktop)을 상호 연동한다.
- 네트워크 토폴로지 상에서 실시간 제어 및 모니터링이 가능하도록 환경을 구축한다.

5. 정보보안 및 프로젝트 유의 사항

가. 작업 간 보안 준수 확인 사항

- 외부 유출 방지: 모의해킹 실습 시 발생하는 모든 공격 패킷(Scapy, Hydra 등)은 반드시 GNS3 내부 격리망 내에서만 순환해야 하며, 외부 공인망이나 교육원 내부 실습망으로 유출되지 않도록 전단 방화벽 정책을 상시 확인한다.
- 공격 스크립트 및 툴 관리 준수: Scapy나 Python을 활용하여 제작한 자동화 공격 코드는 허가되지 않은 타 조의 시스템이나 외부 자산에 절대 실행해서는 안 된다.

나. 프로젝트 수행 점검 리스트

- 네트워크 연동성: 서로 다른 서브넷 간의 핑(Ping) 테스트 및 라우팅 경로가 단절 없이 정상적으로 도달하는가?
- 보안 영역 격리성: 외부 WAN 영역에서 DMZ를 거치지 않고 내부망(LAN)으로 직접 접근하는 비인가 트래픽이 방화벽 규칙에 의해 정확히 차단되는가?
- 공격에 대한 방어 메커니즘 검증: 공격팀의 무차별 대입 및 RIP 스푸핑 시도가 블루팀의 보안 설정(ACL, MD5 인증, DHCP 스누핑 등) 적용 후에 효과적으로 탐지 및 차단 되는가?

6. 프로젝트 진행 산출물 제출 안내

- 제출 양식: KDT 공인 PPT 형식(타 양식도 가능)

- **필수 기재:** 성명, 문제번호, 머리말(이름), 쪽번호 명시